MailFlow: Automação de Envio de E-mails (Transacional, Lembretes e Relatórios)

Versão 1.0 · Documento de Requisitos e Especificações · Regras e limites conferidos em 08/11/2026

1. Visão Geral

1.1 Objetivo

Construir uma plataforma que **envia e-mails de forma automatizada, confiável e em conformidade**: confirmações e recibos disparados por eventos, lembretes programados (por exemplo, vencimento ou consulta), relatórios periódicos com anexo e comunicados em lote para quem consentiu. O sistema controla fila, limites, falhas, bounces, descadastro e métricas.

1.2 Problema real

Pequenas empresas (escolas, clínicas, escritórios de contabilidade, academias) enviam e-mails manualmente ou por planilha: esquecem prazos, repetem mensagens, enviam para endereços inválidos, ignoram pedidos de descadastro e têm e-mails caindo em spam sem saber por quê. Automatizar bem exige mais do que disparar SMTP: exige autenticação de domínio, tratamento de bounces e conformidade com LGPD e com as regras de Gmail, Yahoo e Outlook.

1.3 Objetivos mensuráveis

ID	Objetivo	Meta
OBJ-01	Tempo entre o evento e a entrega ao provedor (transacional)	menor que 30 s (p95)
OBJ-02	Taxa de entrega aceita pelo provedor	maior ou igual a 98%
OBJ-03	Taxa de hard bounce	menor que 2%
OBJ-04	Taxa de reclamação de spam	menor que 0,1% (limite máximo dos provedores: 0,3%)
OBJ-05	Envios duplicados	0

ID	Objetivo	Meta
OBJ-06	Envios a descadastrados ou suprimidos	0
OBJ-07	Custo para desenvolver e testar	R$ 0 (exceto domínio próprio para testes reais)

1.4 Casos de uso do projeto

1. **Transacional por evento:** confirmação de agendamento, recibo, redefinição de acesso.
2. **Lembretes programados:** aviso D-3 e D-0 de vencimento ou compromisso, a partir de planilha CSV ou banco.
3. **Relatório periódico:** resumo mensal em PDF enviado por e-mail aos responsáveis.
4. **Comunicado em lote:** newsletter ou aviso para lista com consentimento, com descadastro em um clique.

2. Verificação de Premissas e Decisões

Conferi as regras e os limites atuais. **Confirme sempre nas páginas oficiais dos provedores antes de produção**, pois planos gratuitos mudam com frequência.

#	Tema	Situação verificada	Decisão no projeto
V1	Regras de remetentes em massa	Gmail, Yahoo e Outlook exigem, de quem envia acima de cerca de 5.000 mensagens/dia a seus usuários, SPF, DKIM e DMARC alinhados, descadastro em um clique (RFC 8058, obrigatório em Gmail e Yahoo; recomendado na Microsoft) e taxa de spam abaixo de 0,3%	Implementar tudo isso desde o MVP, mesmo com volume pequeno
V2	Regras para todos os remetentes	Mesmo com pouco volume valem: SPF ou DKIM, TLS, DNS reverso válido, formato RFC 5322 e baixa taxa de spam	Autenticação completa obrigatória nos testes reais

#	Tema	Situação verificada	Decisão no projeto
V3	Aplicação das regras	Fontes recentes indicam fiscalização mais rígida, com rejeição permanente em vez de envio para spam	Não enviar sem autenticação válida
V4	Descadastro em um clique	Direcionado a e-mails de marketing e inscritos, não a mensagens genuinamente transacionais (recibos, redefinição de acesso)	Classificar cada mensagem como transacional ou promocional; promocional leva os cabeçalhos `List-Unsubscribe`
V5	Provedores gratuitos	SendGrid não tem mais plano gratuito permanente (teste de 60 dias com 100/dia); Resend: 3.000/mês com limite de 100/dia; Brevo: 300/dia com marca da Brevo nos e-mails; Mailgun: 100/dia, 1 domínio, logs curtos; Amazon SES: fontes indicam fim do gratuito para novos clientes após 21/07/2026 (verificar)	Camada de provedor abstrata; testes reais com Resend ou Brevo; SES como opção paga barata para escalar
V6	Gmail/Outlook pessoal via SMTP	Possui limites baixos, exige senha de app e não autentica o seu domínio	Usar apenas para uma demonstração rápida, nunca como solução do projeto
V7	Domínio próprio	Sem domínio próprio não há SPF/DKIM/DMARC alinhados	Único custo possível; alternativa: usar um subdomínio de um domínio que você já tenha, e fazer todo o desenvolvimento com o Mailpit

Decisão: desenvolver contra um **servidor SMTP local de captura (Mailpit)**, que é gratuito e não envia nada para fora; validar com um **provedor real em plano gratuito** usando um domínio de teste; manter o provedor atrás de uma interface para trocar sem reescrever o sistema.

3. Estratégia para Testar e Funcionar (3 ambientes)

Ambiente	Destino dos e-mails	Uso	Custo
Local/CI	Mailpit (SMTP na porta 1025, interface web na 8025) captura tudo; testes consultam a API do Mailpit	Desenvolvimento diário, testes automatizados, revisão visual	R$ 0
Staging real	Provedor gratuito com domínio de teste autenticado, enviando só para caixas de teste suas (Gmail, Outlook, Yahoo, iCloud)	Validar autenticação, entrega, spam e cabeçalhos	R$ 0 a custo do domínio
Produção	Provedor escolhido com domínio verificado e monitoramento	Clientes reais	Conforme volume

Regra de ouro: o código de negócio nunca chama o provedor diretamente. Tudo passa por `EmailProvider` (`send`, `parse_webhook`, `check_domain`). Em desenvolvimento, o adaptador SMTP aponta para o Mailpit.

Trava de segurança: em ambientes que não são produção, o sistema só envia para uma lista de permissão de destinatários de teste; qualquer outro endereço é redirecionado ao Mailpit ou bloqueado. Isso evita o erro clássico de enviar e-mail de teste a clientes reais.

4. Escopo

4.1 Dentro do escopo (MVP)

- API e interface mínima para disparar e-mails transacionais e programar lembretes.
- Templates com variáveis, versão HTML e texto simples, pré-visualização.
- Importação de destinatários por CSV com validação.
- Fila com limite de taxa, retentativas e idempotência.
- Tratamento de bounces, reclamações e lista de supressão por webhook do provedor.
- Descadastro em um clique e página de preferências.
- Relatórios agendados com anexo PDF.
- Verificador de domínio (SPF, DKIM, DMARC) e métricas de entrega.

4.2 Fora do escopo (versão 1)

- Prospecção fria (cold email) e compra de listas.
- Editor visual de arrastar e soltar.
- Recebimento e leitura de respostas (apenas `Reply-To`).
- Servidor de e-mail próprio (MTA) exposto à internet.
- Multi-tenant e cobrança.

4.3 Evolução futura

Segmentação avançada, testes A/B de assunto, gatilhos por eventos externos (webhooks de entrada), painel de reputação, múltiplos provedores com failover.

5. Personas

Persona	Necessidade
Operador da empresa	Programar lembretes e comunicados sem depender de planilhas
Desenvolvedor integrador	API simples para disparar e-mails por evento
Gestor	Saber quantos e-mails chegaram, quebraram ou geraram reclamação
Destinatário	Receber só o que pediu e conseguir sair da lista facilmente
Você (aprendizado)	Ambiente seguro, reprodutível e sem custo para testar

6. Requisitos Funcionais

Prioridade MoSCoW: **M** (must), **S** (should), **C** (could).

ID	Requisito	Prior.
RF-01	Enviar e-mail transacional por `POST /api/v1/messages` com template, destinatário, variáveis e chave de idempotência	M
RF-02	Gerenciar templates (criar, versionar, pré-visualizar) com HTML e texto simples obrigatórios	M

ID	Requisito	Prior.
RF-03	Validar variáveis do template antes do envio e falhar com erro claro se faltar alguma	M
RF-04	Importar destinatários por CSV com validação de sintaxe, domínio e duplicidades	M
RF-05	Programar envios (data/hora ou regra relativa, por exemplo, 3 dias antes do vencimento) com fuso horário	M
RF-06	Enfileirar envios e processar com limite de taxa por provedor e por domínio de destino	M
RF-07	Garantir idempotência: a mesma chave nunca gera dois envios	M
RF-08	Retentar falhas temporárias com backoff exponencial e enviar para fila de falhas após o limite	M
RF-09	Receber webhooks do provedor (entregue, bounce, reclamação, abertura, clique) com validação de assinatura	M
RF-10	Manter lista de supressão global (hard bounce, reclamação, descadastro) e bloquear envios a ela	M
RF-11	Incluir `List-Unsubscribe` e `List-Unsubscribe-Post` em mensagens promocionais e link visível de descadastro	M
RF-12	Processar descadastro em um clique e confirmar, em até 48 h (meta: imediato)	M
RF-13	Classificar cada mensagem como transacional ou promocional e aplicar regras distintas	M
RF-14	Registrar consentimento (origem, data, finalidade) por destinatário	M
RF-15	Gerar relatório PDF agendado e anexar ao e-mail	S
RF-16	Verificar a configuração do domínio (SPF, DKIM, DMARC) e exibir pendências	S
RF-17	Aquecimento gradual (warm-up): limite diário crescente em domínios ou IPs novos	S

ID	Requisito	Prior.
RF-18	Painel de métricas: enviados, entregues, bounce, reclamação, abertura e clique	S
RF-19	Modo de teste com lista de permissão e redirecionamento ao Mailpit	M
RF-20	Pausar e retomar campanhas; cancelar envios pendentes	S
RF-21	Exportar log de envios e consentimentos (CSV)	C
RF-22	Expor `GET /health` e `GET /metrics`	S

7. Requisitos Não Funcionais

ID	Categoria	Requisito
RNF-01	Desempenho	Evento transacional entregue ao provedor em até 30 s (p95) com fila normal
RNF-02	Confiabilidade	Nenhuma mensagem perdida em reinício; entrega "pelo menos uma vez" na fila com idempotência garantindo "no máximo uma" no resultado
RNF-03	Escalabilidade	Workers escaláveis horizontalmente; suporta 10.000 envios/dia em hardware modesto
RNF-04	Segurança	Chaves de API em variáveis de ambiente; assinatura de webhooks verificada; tokens de descadastro assinados e não previsíveis
RNF-05	Privacidade	LGPD: minimização, retenção configurável, exclusão sob demanda, e-mails mascarados em logs
RNF-06	Observabilidade	Logs estruturados com `message_id`, `campaign_id` e métricas por etapa
RNF-07	Portabilidade	`docker compose up` sobe API, worker, banco, Redis e Mailpit
RNF-08	Testabilidade	Testes automatizados contra o Mailpit; cobertura maior ou igual a 80% em templates, fila e regras de supressão

ID	Categoria	Requisito
RNF-09	Compatibilidade	E-mails renderizam bem nos principais clientes (Gmail, Outlook, Apple Mail, celular)
RNF-10	Acessibilidade	Texto alternativo em imagens, contraste adequado e versão em texto simples

8. Regras de Negócio

- **RN-01 (consentimento):** mensagens promocionais só vão a quem tem base legítima registrada e finalidade compatível; sem registro, não há envio.
- **RN-02 (transacional é transacional):** mensagens transacionais não podem conter conteúdo promocional relevante, sob pena de serem tratadas como marketing.
- **RN-03 (supressão):** hard bounce e reclamação suprimem o endereço imediatamente; soft bounce suprime após N falhas consecutivas (padrão 3).
- **RN-04 (descadastro):** pedido de descadastro é aplicado de imediato e nunca depois de 2 dias; não exige login nem confirmação extra.
- **RN-05 (identificação):** todo e-mail promocional traz nome do remetente, dados da empresa e como falar com ela.
- **RN-06 (remetente alinhado):** o domínio do `From` deve coincidir com o domínio autenticado por SPF ou DKIM.
- **RN-07 (idempotência):** a combinação (campanha, destinatário, ocorrência) é única.
- **RN-08 (horário):** lembretes e comunicados respeitam janela de envio (padrão 08h às 20h no fuso do destinatário), exceto transacionais urgentes.
- **RN-09 (limites):** respeitar limites diário e por segundo do provedor; excedente fica na fila.
- **RN-10 (reputação):** se a taxa de reclamação ou de bounce passar do limite configurado, campanhas promocionais são pausadas automaticamente e o operador é avisado.
- **RN-11 (cobrança respeitosa):** lembretes de débito usam linguagem neutra e não expõem o destinatário a constrangimento (valide as regras do Código de Defesa do Consumidor).
- **RN-12 (anexos):** limite de tamanho (padrão 5 MB) e tipos permitidos; anexos sensíveis preferem link com expiração.

9. Arquitetura

9.1 Fluxo principal

1. Um evento chega pela API (ou o agendador dispara o lembrete).
2. A API valida, checa supressão e idempotência, grava a mensagem como `QUEUED` e a publica na fila.
3. O worker renderiza o template (HTML e texto), adiciona cabeçalhos e anexos e aplica o limite de taxa.
4. O worker envia pelo `EmailProvider`; o resultado vira `SENT` ou `RETRY` / `FAILED`.
5. O provedor chama o webhook com `delivered`, `bounce`, `complaint`, `open` e `click`.
6. O sistema atualiza o status, alimenta a lista de supressão e as métricas.
7. Descadastro: o destinatário clica, a requisição `POST` do cliente de e-mail ou da página marca a supressão.

9.2 Stack recomendada (gratuita)

Camada	Tecnologia	Observação
Linguagem/API	Python 3.12 + FastAPI	Documentação OpenAPI
Templates	Jinja2 (opcional: MJML para HTML responsivo)	HTML e texto simples
Fila e agendador	Redis + Celery (ou RQ/arq) com Celery Beat	Limites e retentativas
Banco	PostgreSQL 16	Mensagens, consentimentos, supressão
PDF	WeasyPrint ou ReportLab	Relatórios
E-mail (dev)	Mailpit	SMTP de captura com interface e API
E-mail (real)	Resend ou Brevo (gratuito), SES (opção paga barata)	Via interface `EmailProvider`
Testes	pytest, httpx, respx	Asserts via API do Mailpit
Verificação DNS	dnspython	SPF, DKIM, DMARC
Infra	Docker Compose	api, worker, beat, db, redis, mailpit

9.3 Estrutura do repositório

```
mailflow/
  docker/
  src/
    api/ (rotas, webhooks, descadastro)
    providers/ (base.py, smtp.py, resend.py, brevo.py, ses.py)
    templates/ (arquivos .html.j2 e .txt.j2)
    rendering/ (validação de variáveis, PDF)
    queue/ (tarefas, limite de taxa, retentativas)
    scheduler/ (regras e fusos)
    suppression/ (bounce, reclamação, descadastro)
    consent/ (registro e histórico)
    domain/ (verificador SPF/DKIM/DMARC)
    db/ (modelos e migrações)
  tests/ (unit, integration, deliverability)
  docs/
```

10. Configuração do Domínio e Autenticação

O provedor mostra os valores exatos. O padrão geral é:

1. **Subdomínio de envio** (por exemplo, `mail.seudominio.com.br`), separando a reputação do domínio principal.
2. **SPF:** registro TXT que autoriza o provedor, no formato `v=spf1 include:<dominio-do-provedor> ~all`.
3. **DKIM:** registros fornecidos pelo provedor (CNAME ou TXT) para assinar as mensagens.
4. **DMARC:** registro TXT em `_dmarc.seudominio.com.br`, começando com `v=DMARC1; p=none; rua=mailto:relatorios@seudominio.com.br`; endurecer para `quarantine` e depois `reject` após observar os relatórios.
5. **Alinhamento:** o `From` deve usar o mesmo domínio (ou subdomínio alinhado) autenticado.
6. **Domínio de retorno (bounce)** configurado conforme o provedor.
7. **Verificação:** enviar para uma caixa Gmail de teste e abrir *Mostrar original* para conferir SPF, DKIM e DMARC como PASS.

Cabeçalhos de descadastro em mensagens promocionais:

```
List-Unsubscribe: <https://app.seudominio.com.br/u/TOKEN>,
<mailto:descadastro@seudominio.com.br?subject=unsubscribe>
List-Unsubscribe-Post: List-Unsubscribe=One-Click
```

O cabeçalho deve estar coberto pela assinatura DKIM, e o endpoint deve aceitar `POST` sem login.

11. Modelo de Dados

recipients: id, email (único, normalizado), nome, fuso, status (`ACTIVE`, `SUPPRESSED`), criado_em.

consents: id, recipient_id, finalidade, base_legal, origem, registrado_em, revogado_em.

templates: id, nome, versao, assunto, html, texto, variaveis_obrigatorias, tipo (`TRANSACTIONAL`, `PROMOTIONAL`).

campaigns: id, nome, template_id, tipo, status, janela_envio, criada_em.

messages: id, campaign_id, recipient_id, idempotency_key (única), status, provider_message_id, tentativas, erro, agendada_para, enviada_em.

events: id, message_id, tipo (`delivered`, `bounce_hard`, `bounce_soft`, `complaint`, `open`, `click`, `unsubscribe`), payload, ocorrido_em.

suppressions: id, email, motivo, origem, criado_em.

schedules: id, campaign_id, regra, proxima_execucao, fuso.

domain_checks: id, dominio, spf_ok, dkim_ok, dmarc_ok, verificado_em.

12. Templates, Fila e Aquecimento

12.1 Templates

- Sempre HTML e texto simples; assunto objetivo; sem anexos desnecessários.
- Variáveis obrigatórias declaradas; renderização falha de forma explícita se faltar valor.
- Largura máxima de 600 px, imagens com texto alternativo, links com domínio próprio, sem encurtadores de terceiros.
- Testes de *snapshot* de HTML para detectar mudanças acidentais.

12.2 Fila, limites e retentativas

- Limite configurável por provedor (por segundo e por dia) e por domínio de destino.
- Erros 4xx/temporários: backoff exponencial (por exemplo 1, 5, 30 minutos), no máximo de 5 tentativas.
- Erros 5xx permanentes ou endereço inválido: `FAILED` sem nova tentativa e supressão quando aplicável.

- Chave de idempotência verificada antes de enviar e também enviada ao provedor, quando suportado.

12.3 Aquecimento (warm-up)

Para domínio novo, começar com volume baixo e crescer: por exemplo 50 no dia 1, dobrando a cada poucos dias enquanto bounce e reclamação ficam dentro das metas, priorizando destinatários mais engajados.

13. API Interna (resumo)

Rota	Função
POST /api/v1/messages	Envia mensagem transacional (idempotente)
POST /api/v1/campaigns	Cria campanha ou lembrete programado
POST /api/v1/recipients/import	Importa CSV com validação
GET /api/v1/messages/{id}	Status e eventos
POST /api/v1/campaigns/{id}/pause	Pausa e retoma campanha
POST /webhooks/{provedor}	Eventos do provedor (assinatura obrigatória)
GET e POST /u/{token}	Descadastro (suporta one-click por POST)
GET /api/v1/domain/check	Verifica SPF, DKIM e DMARC
GET /api/v1/metrics	Indicadores de entrega
GET /health	Saúde

14. Metodologia

- **Processo:** Scrum leve com sprints de 1 semana; cada sprint termina com uma demonstração vendo os e-mails no Mailpit e, a partir da Sprint 4, nas caixas reais.
- **Ordem de construção:** primeiro o núcleo (templates, fila, idempotência) contra o Mailpit; depois webhooks e supressão; só depois provedor real e domínio.
- **TDD** para regras de supressão, idempotência, janela de envio e validação de templates.
- **Contract tests** com payloads reais gravados dos webhooks do provedor.
- **Testes de entregabilidade** em checklist manual, repetidos a cada mudança de template ou domínio.

- **Experimentos:** comparar provedores (Resend, Brevo) em tempo de entrega, qualidade dos webhooks e limites; registrar em tabela no repositório.

15. Estratégia de Testes

Nível	Escopo	Ferramentas
Unitário	Renderização, validação de e-mail, regras de supressão, janelas de horário	pytest
Integração	API, fila, banco e Mailpit reais; asserts no conteúdo e nos cabeçalhos recebidos	pytest + docker compose
Contrato	Parsing dos webhooks do provedor	payloads gravados
Entregabilidade	SPF/DKIM/DMARC PASS, `List-Unsubscribe`, chegada à caixa de entrada nos provedores	checklist manual + `domain/check`
Renderização	Visual em Gmail, Outlook, Apple Mail e celular	revisão manual e capturas
Resiliência	Provedor fora do ar, timeout, reinício do worker, evento duplicado	pytest com falhas simuladas
Carga	5.000 mensagens na fila respeitando limite de taxa	script ou locust
Segurança	Webhook sem assinatura, token de descadastro adulterado, injeção de cabeçalho (quebras de linha em assunto ou destinatário)	pytest

16. Critérios de Aceite

16.1 Critérios funcionais (Gherkin)

CA-01 Envio transacional

- Dado um template válido e um destinatário de teste
- Quando eu chamar `POST /api/v1/messages`
- Então o e-mail aparece no Mailpit em até 30 s com HTML, texto simples e variáveis substituídas.

CA-02 Idempotência

- Dada a mesma chave de idempotência enviada duas vezes
- Então apenas um e-mail é enviado e a segunda chamada retorna o mesmo resultado.

CA-03 Variável ausente

- Dado um template que exige `nome` e `vencimento`
- Quando faltar `vencimento`
- Então o sistema recusa com erro claro e nada é enviado.

CA-04 Importação

- Dado um CSV com e-mails válidos, inválidos e duplicados
- Então só os válidos e únicos são importados e o relatório lista os rejeitados com o motivo.

CA-05 Lembrete programado

- Dada uma regra de aviso 3 dias antes do vencimento
- Então o e-mail é gerado na data certa, no fuso do destinatário e dentro da janela de envio.

CA-06 Limite de taxa

- Dada uma fila com mais mensagens do que o limite do provedor
- Então o excedente aguarda e nenhuma mensagem é rejeitada por excesso de taxa.

CA-07 Retentativa

- Dada uma falha temporária do provedor
- Então o sistema tenta novamente com backoff e a mensagem não é duplicada nem perdida.

CA-08 Hard bounce

- Dado um webhook de hard bounce
- Então o endereço entra na supressão e envios futuros a ele são bloqueados.

CA-09 Reclamação de spam

- Dado um webhook de reclamação
- Então o endereço é suprimido imediatamente e o evento é contabilizado na métrica.

CA-10 Descadastro em um clique

- Dada uma mensagem promocional
- Então ela contém `List-Unsubscribe` e `List-Unsubscribe-Post`, e o `POST` ao endpoint suprime o destinatário sem login.

CA-11 Transacional não é bloqueado por promoção

- Dado um destinatário descadastrado de promoções
- Então ele ainda recebe recibos e confirmações, mas nunca comunicados promocionais.

CA-12 Modo de teste seguro

- Dado o ambiente de staging
- Quando eu tentar enviar a um endereço fora da lista de permissão
- Então o envio é bloqueado ou redirecionado ao Mailpit.

CA-13 Webhook inválido

- Dado um webhook com assinatura incorreta
- Então o sistema responde 401 e não altera nenhum dado.

CA-14 Relatório PDF

- Dado um relatório mensal programado
- Então o e-mail chega com o PDF anexo, abaixó de 5 MB e com o conteúdo correto.

CA-15 Injeção de cabeçalho

- Dado um nome ou assunto contendo quebra de linha e cabeçalho falso
- Então o sistema neutraliza ou recusa a entrada e nenhum cabeçalho extra é criado.

16.2 Checklist manual de entregabilidade (staging real)

1. Domínio verificado no provedor e `domain/check` com SPF, DKIM e DMARC em PASS.
2. E-mail chega à **caixa de entrada** (não ao spam) em Gmail, Outlook, Yahoo e iCloud de teste.
3. *Mostrar original* no Gmail confirma SPF, DKIM e DMARC como PASS e domínio alinhado.
4. O botão de cancelar inscrição do Gmail aparece e funciona em mensagem promocional.
5. Layout correto no celular e no Outlook.
6. Bounce simulado (endereço inexistente no seu domínio de teste) entra na supressão.
7. Nenhum link quebrado, imagens com texto alternativo e versão em texto simples legível.

16.3 Metas de qualidade

Indicador	Mínima	Desejável
Evento até o provedor (p95)	menor que 30 s	menor que 10 s

Indicador	Mínima	Desejável
Entrega aceita	98%	99,5%
Hard bounce	menor que 2%	menor que 0,5%
Reclamação de spam	menor que 0,1%	menor que 0,05%
Duplicados	0	0
Envios a suprimidos	0	0
Descadastro processado	em até 48 h	imediato
Cobertura de testes (núcleo)	80%	90%

17. Segurança, Privacidade e Conformidade

- **Segredos:** chaves de API do provedor em variáveis de ambiente, nunca no repositório; chaves com permissão mínima de envio.
- **Webhooks:** validar assinatura, aceitar apenas IPs/segredos esperados e processar de forma idempotente.
- **Tokens de descadastro:** assinados (HMAC) e sem dados pessoais legíveis.
- **Injeção de cabeçalho:** rejeitar `\r` e `\n` em campos usados em cabeçalhos.
- **Anti-abuso:** limite de taxa na API; não expor o endpoint de envio sem autenticação para não virar retransmissor de spam.
- **LGPD:** coletar o mínimo, registrar base legal e finalidade, informar como sair da lista, reter por prazo definido e excluir sob demanda; mascarar e-mails em logs.
- **Conteúdo:** nada de dados sensíveis no corpo; preferir links com expiração a anexos confidenciais.
- **Aviso:** este documento não é parecer jurídico; valide LGPD e regras de cobrança com um profissional ao usar com clientes reais.

18. Custos e Limites

Item	Desenvolvimento e teste	Produção pequena
SMTP local (Mailpit)	R$ 0	Não se aplica

Item	Desenvolvimento e teste	Produção pequena
Provedor gratuito	Resend: 3.000/mês, máximo 100/dia; Brevo: 300/dia com marca no e-mail; Mailgun: 100/dia (conferir os planos vigentes)	Planos pagos a partir de poucos dólares/mês; SES cobra cerca de US$ 0,10 por mil e-mails (conferir)
Domínio	Pode usar um que você já tenha (subdomínio)	Anual, valor baixo
Hospedagem	Máquina local	VPS pequeno
Monitoramento	Google Postmaster Tools (gratuito)	Idem

Atenção: os limites diários dos planos gratuitos (100 a 300) restringem testes de carga reais. Teste volume contra o Mailpit e valide só amostras no provedor.

19. Plano de Entrega

Sprint	Entregas	Resultado verificável
0	Repositório, Docker (API, worker, Redis, Postgres, Mailpit), `EmailProvider` com adaptador SMTP	E-mail de teste aparece no Mailpit
1	Templates, validação de variáveis, envio transacional idempotente	CA-01, CA-02, CA-03, CA-15
2	Importação CSV, consentimento, agendamento e janelas de horário	CA-04, CA-05
3	Fila com limite de taxa, retentativas e fila de falhas	CA-06, CA-07
4	Domínio de teste, provedor real (Resend ou Brevo), verificador de domínio, checklist 16.2	Autenticação PASS e caixa de entrada
5	Webhooks, supressão, descadastro em um clique, transacional versus promocional	CA-08 a CA-13
6	Relatórios PDF, métricas, pausa automática por reputação	CA-14 e metas 16.3
7	Aquecimento, LGPD, documentação e demonstração	Entrega final

20. Riscos e Mitigações

Risco	Prob.	Impacto	Mitigação
E-mails caem em spam	Alta	Alto	Autenticação completa, aquecimento, conteúdo limpo, lista consentida, monitoramento
Enviar teste a clientes reais	Média	Alto	Lista de permissão e redirecionamento ao Mailpit fora de produção
Provedor gratuito muda limites ou plano	Alta	Médio	Interface de provedor, limites em configuração e revisão das páginas oficiais
Reclamações de spam acima do limite	Média	Alto	Descadastro fácil, segmentação, pausa automática
Envio duplicado por retentativa	Média	Médio	Idempotência em banco e no provedor
Endpoint de envio abusado como retransmissor	Média	Alto	Autenticação, limite de taxa, validação de destinatários
Dados pessoais em logs	Média	Alto	Mascaramento e retenção limitada
Falta de domínio próprio atrasa a validação real	Média	Médio	Usar subdomínio existente ou concluir o MVP no Mailpit e validar depois
Renderização ruim no Outlook	Média	Baixo	HTML simples em tabelas, MJML e revisão manual

21. Definição de Pronto (DoD)

- Código revisado, lint e tipagem passando no CI.
- Testes unitários, de integração e de contrato verdes.
- Checklist de entregabilidade 16.2 executado quando houver mudança de domínio, provedor ou template base.
- Nenhuma chave, e-mail real ou dado pessoal no repositório.
- OpenAPI e README atualizados.

22. Glossário

- **SPF:** registro DNS que lista quem pode enviar e-mail pelo seu domínio.
- **DKIM:** assinatura criptográfica que prova que a mensagem não foi alterada e vem do domínio.
- **DMARC:** política que diz o que fazer quando SPF/DKIM falham e pede relatórios.
- **Alinhamento:** o domínio do `From` coincide com o autenticado.
- **Hard bounce / soft bounce:** falha permanente / temporária de entrega.
- **Idempotência:** repetir a mesma chamada não repete o efeito.
- **One-click unsubscribe (RFC 8058):** descadastro feito pelo próprio cliente de e-mail com uma requisição `POST`.
- **Warm-up:** aumento gradual de volume para construir reputação.
- **Mailpit:** servidor SMTP local de teste que captura e exibe e-mails.
- **Lista de supressão:** endereços aos quais nunca se deve enviar.

23. Variações de Projeto (para comparação)

1. **Lembretes de vencimento para escritório de contabilidade:** foco no caso de uso 2, com integração a planilhas; menor risco de spam, pois é transacional.
2. **Newsletter para comunidade ou associação:** foco no caso de uso 4 e em descadastro, segmentação e métricas.
3. **Relatórios automáticos por e-mail (BI leve):** foco no caso de uso 3, com PDF e gráficos agendados.

A recomendação é começar pelos casos 1 e 2 (transacional e lembretes), que dão valor rápido, geram poucas reclamações e permitem aprender entregabilidade antes de partir para campanhas em lote.